

Incident Response & Forensic Analysis Report: PhishStrike Lab

1. Executive Summary

This report details the forensic investigation of a network breach simulated in the "PhishStrike" lab scenario. The investigation utilized network capture (PCAP) analysis to uncover a critical compromise of a JetBrains TeamCity continuous integration server.

The attacker, operating from IP address 23.158.56.196, successfully exploited a critical authentication bypass vulnerability (CVE-2024-27198) in TeamCity version 2023.11.3. Following initial access, the attacker deployed a persistent webshell, created an unauthorized administrative account, manipulated local credential files, and attempted to escape the containerized environment. While the container escape attempts were unsuccessful, the attacker achieved deep system compromise and data manipulation.

2. Investigation Methodology & Tools

The analysis was conducted using industry-standard network forensics tools to reconstruct the attack timeline and extract artifacts.

- **Wireshark:** Used for deep packet inspection, HTTP traffic filtering, endpoint analysis, and TCP stream reconstruction.
- **NetworkMiner:** Utilized for rapid endpoint identification and file extraction from network streams.
- **Brim:** Used for high-level network flow analysis and behavioral patterning.
- **MITRE ATT&CK Framework:** Referenced to classify attacker tactics, techniques, and procedures (TTPs).

3. Detailed Findings & Attack Timeline

Phase 1: Initial Access & Vulnerability Exploitation

The initial attack vector was identified by examining HTTP communications within the PCAP.

- **Attacker IP:** 23.158.56.196 (identified via Wireshark Statistics > Endpoints > HTTP).
- **Target Software:** JetBrains TeamCity.
- **Target Version:** 2023.11.3 (Build 147512) (revealed in HTTP response headers).
- **Vulnerability Exploited:** **CVE-2024-27198**. This is a critical authentication bypass vulnerability in TeamCity that allows unauthenticated attackers to execute administrative actions.

Phase 2: Execution & Persistence (Webshell Deployment)

To establish persistent remote control, the attacker uploaded a malicious payload disguised as a plugin/archive.

- **Artifact Uploaded:** NSt8bHTg.zip
- **Mechanism:** The attacker sent an HTTP POST request uploading this file. Analysis of the HTTP stream revealed Java code snippets within the payload designed to decode commands sent via HTTP parameters and execute them on the server.
- **First Execution:** The attacker successfully executed their first command via the deployed webshell (NSt8bHTg.jsp) on **Sunday, June 30, 2024, at 08:03:57 GMT (UTC)**.

Phase 3: Privilege Escalation & Account Creation

Leveraging the webshell and the compromised administrative capabilities of CVE-2024-27198, the attacker created a backdoor account to ensure persistent access.

- **Action:** An HTTP POST request was sent to the endpoint `/hax.jsp/app/rest/server/users.jsp`.
- **New Account Credentials:**
 - **Username:** c91oyemwand
 - **Password:** CL5vzdwLuK
- **Email Assigned:** C19oyem@example.com
- **Privileges:** The account was explicitly granted the `SYSTEM_ADMIN` role, providing the attacker with top-level control over the TeamCity environment.

Phase 4: Data Manipulation & Credential Theft

The attacker utilized the webshell to manipulate local files on the compromised host, specifically targeting credential stores.

- **Action:** The attacker executed a bash command via the webshell to overwrite a local credentials file.
- **Command Executed:** `bash -c 'echo "username:a1l4m,password:youarecompromised" > /tmp/Creds.txt+'`
- **Impact:** The file `/tmp/Creds.txt`, which likely contained legitimate administrative credentials, was tampered with and overwritten with the attacker's specified text.
- **MITRE ATT&CK Classification:** This action maps directly to **T1565.001 (Data Manipulation: Stored Data)**, as the attacker modified stored data to potentially intercept authentication or disrupt normal operations.

Phase 5: Container Escape Attempts (Unsuccessful)

Believing the compromised service was running inside a Docker container, the attacker attempted multiple container escape techniques to access the underlying host system. All attempts failed, likely due to insufficient permissions or restricted Docker configurations on the target.

1. Privileged Container Attempt:

- *Command:* `docker run --rm -it --privileged ubuntu`
- *Intent:* Launch a new container with the `--privileged` flag, which grants the container extensive host system permissions, effectively bypassing container isolation.

2. Host Filesystem Mount Attempt:

- *Command:* `docker run --rm -it -v /:/host ubuntu chroot /host`
- *Intent:* Mount the host's root directory (`/`) into the container at `/host` and use `chroot` to change the root directory, allowing direct interaction with host files.

3. Docker Socket Mount Attempt:

- *Command:* `docker run -v /var/run/docker.sock:/var/run/docker.sock -it ubuntu`
- *Intent:* Mount the host's Docker socket into the container. This allows the attacker to control the host's Docker daemon, enabling them to spawn new privileged containers or manipulate existing ones.

4. Indicators of Compromise (IOCs)

Type	Indicator	Description
IP Address	23.158.56.196	Attacker source IP
File Name	NSt8bHTg.zip	Malicious uploaded archive
Webshell	NSt8bHTg.jsp	Deployed webshell for command execution

Type	Indicator	Description
Account	c91oyemwand	Unauthorized SYSTEM_ADMIN account created
Password	CL5vzdwLuK	Password for rogue account
Target File	/tmp/Creds.txt	Local file tampered with by attacker
Command	docker run --rm -it --privileged ubuntu	Failed container escape attempt

5. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Initial Access	Exploit Public-Facing Application	T1190	Exploitation of CVE-2024-27198 on TeamCity.
Persistence	Server Software Component: Web Shell	T1505.003	Upload and use of NSt8bHTg.jsp.
Persistence	Create Account	T1136	Creation of c91oyemwand with SYSTEM_ADMIN rights.
Execution	Command and Scripting Interpreter	T1059	Execution of bash commands via webshell.
Defense Evasion	Data Manipulation: Stored Data	T1565.001	Overwriting /tmp/Creds.txt.
Privilege Escalation	Escape to Host	T1611	Attempted Docker container escapes (privileged, mounts, socket).

6. Remediation & Recommendations

Based on the findings of this investigation, the following remediation steps are strongly recommended to secure the environment and prevent recurrence:

1. **Patch and Upgrade:** Immediately upgrade the JetBrains TeamCity server to version **2023.11.4 or later**, which addresses the critical CVE-2024-27198 authentication bypass vulnerability.
2. **Artifact Removal:**
 - Delete the malicious webshell (NSt8bHTg.jsp) and the uploaded archive (NSt8bHTg.zip) from the server.
 - Delete the unauthorized user account (c91oyemwand).
3. **Credential Rotation:** As the attacker tampered with /tmp/Creds.txt and had SYSTEM_ADMIN access, assume all credentials associated with the TeamCity server, its database, and connected CI/CD pipelines are compromised. Force a global password reset and rotate all API keys and service account credentials.
4. **File Restoration:** Restore the contents of /tmp/Creds.txt from a known, secure backup.
5. **Container Security Hardening:** Although the escape attempts failed, implement strict Docker security controls:
 - Ensure the Docker daemon runs with least privilege.
 - Restrict access to /var/run/docker.sock.
 - Use AppArmor or SELinux profiles to enforce container isolation.
6. **Network Defense:** Implement network-level blocks (firewall/IDS) for the attacker IP address 23.158.56.196 and monitor for outbound connections to this IP.